



AGRO-SMART

Sistema Inteligente de Monitoreo y Control de Riego Agrícola

POLÍTICA DE PRIVACIDAD Y TRATAMIENTO DE DATOS PERSONALES

Documento Oficial

Versión 1.0 | Julio 2026

Control del documento e historial de versiones

1.1 Historial de versiones

Versión	Fecha	Autor(es)	Descripción del cambio	Estado
1.0	Julio 2026	Equipo Agro-Smart (UNL)	Elaboración inicial de la Política de Privacidad adaptada al sistema Agro-Smart v1.0.	Aprobado

1.2 Control del documento

Campo	Detalle
Título del documento	Política de Privacidad y Tratamiento de Datos Personales - Agro-Smart
Código	AGRS-POL-PRIV-001
Versión actual	1.0
Fecha de vigencia	Julio 2026
Responsable de elaboración	Equipo de Desarrollo Agro-Smart - Universidad Nacional de Loja
Revisado por	Luis Armijos
Aprobado por	Joel Tapia
Clasificación	Externa - Publicado
Marco normativo de referencia	Ley Orgánica de Protección de Datos Personales del Ecuador (LOPDPE); principios GDPR; ISO/IEC 27001; ISO/IEC 27701; Privacy by Design

Tabla de Contenido

Control del documento e historial de versiones	2
1.1 Historial de versiones	2
1.2 Control del documento	2
Tabla de contenido.....	3
2. Introducción	5
3. Objetivo de la política de privacidad	5
4. Alcance.....	5
5. Definiciones y terminología.....	6
6. Información del responsable del tratamiento.....	7
7. Datos personales recopilados	8
7.1 Datos de identificación y cuenta de usuario	8
7.2 Datos de seguridad y control de acceso	8
7.3 Datos operativos y de configuración	9
8. Datos técnicos recopilados e información proveniente de dispositivos IoT	10
8.1 Telemetría de sensores IoT	10
8.2 Credenciales de dispositivos IoT	10
8.3 Datos del Autómata Finito Determinista (AFD)	10
8.4 Datos del microservicio de auditoría	10
9. Finalidades del tratamiento de datos	12
10. Base legal del tratamiento	13
11. Consentimiento del usuario	13
12. Uso de Cookies y tecnologías de seguimiento	14
12.1 Cookies de sesión	14
12.2 Google reCAPTCHA.....	14
12.3 Comunicaciones en tiempo real (WebSocket).....	14
12.4 Tecnologías de seguimiento analítico.....	14
13. Compartición de información con terceros y servicios externos	15
13.1 Principio general	15
13.2 Servicios externos utilizados en el sistema	15
13.3 Transferencias internacionales de datos.....	15
14. Conservación de la información	16
15. Medidas de seguridad implementadas	17
15.1 Seguridad en la autenticación	17
15.2 Seguridad en el transporte de datos.....	17
15.3 Seguridad en la autorización y el acceso a datos	17
15.4 Seguridad de la infraestructura	17
15.5 Seguridad en el desarrollo	18
16. Derechos de los usuarios	19
16.1 Catálogo de derechos	19
16.2 Procedimiento para ejercer los derechos.....	19
17. Responsabilidades del usuario	20



18. Protección de menores de edad.....	20
19. Gestión de incidentes de seguridad relacionados con datos personales	21
19.1 Definición de incidente	21
19.2 Clasificación de incidentes	21
19.3 Procedimiento de respuesta	21
20. Modificaciones de la política de privacidad.....	22
21. Información de contacto.....	22
22. Referencias normativas	23
23. Anexos.....	24
Anexo A - Inventario de datos personales tratados por Agro-Smart	24
Anexo B - Arquitectura de protección de datos en Agro-Smart	24
Anexo C - Flujo de datos personales en el proceso de autenticación	24



2. Introducción

Agro-Smart es un sistema de software y hardware desarrollado en el marco del Trabajo Final de Titulación de la Carrera de Computación de la Universidad Nacional de Loja (UNL), Ecuador. La plataforma integra tecnologías de Internet de las Cosas (IoT), computación en la nube (Google Cloud Platform) y arquitectura de microservicios para ofrecer un servicio de monitoreo automático de variables ambientales (humedad del suelo y temperatura ambiente) y control inteligente del riego agrícola en cultivos de pequeña escala.

Con el propósito de garantizar la transparencia en el tratamiento de la información personal que el sistema recopila, almacena y procesa, el equipo Agro-Smart ha elaborado el presente documento, que constituye la Política de Privacidad y Tratamiento de Datos Personales oficial de la plataforma.

Esta política ha sido redactada tomando como referencia la Ley Orgánica de Protección de Datos Personales del Ecuador (LOPD), los principios del Reglamento General de Protección de Datos de la Unión Europea (GDPR) como guía de buenas prácticas internacionales, el estándar ISO/IEC 27701 sobre gestión de privacidad de la información, y el paradigma de Privacidad por Diseño (Privacy by Design). La alineación con estos marcos regulatorios y normativos se adopta como guía estructural; no implica una certificación formal ni una declaración de cumplimiento jurídico en todas las jurisdicciones aplicables.

3. Objetivo de la política de privacidad

El presente documento tiene por objetivos:

- Informar a los usuarios de la plataforma Agro-Smart -con claridad, precisión y sin ambigüedades- sobre qué datos personales son recopilados, con qué finalidad, bajo qué base legal, durante cuánto tiempo y de qué manera son protegidos.
- Establecer los principios rectores que guían el tratamiento de datos personales en todos los componentes del sistema, incluyendo la capa de percepción (nodos IoT), la capa de procesamiento (backend Node.js, base de datos PostgreSQL, broker MQTT) y la capa de presentación (interfaz web React).
- Describir los derechos que asisten a los titulares de los datos y los mecanismos disponibles para ejercerlos.
- Definir las responsabilidades del equipo de desarrollo Agro-Smart en materia de privacidad y seguridad de la información.
- Servir como documento de referencia para auditorías internas, evaluaciones académicas y como base para la futura publicación en la plataforma cuando esta entre en operación real.

4. Alcance

Esta política es aplicable a:

- Todos los usuarios registrados en la plataforma Agro-Smart, incluyendo los roles de SuperAdministrador, Administrador y Agricultor, independientemente del contexto desde el cual accedan al sistema (entorno de desarrollo, pruebas o producción).
- Todos los datos personales y técnicos generados, transmitidos, almacenados o procesados a través de los componentes del sistema: interfaz web, API REST, servidor WebSocket (Socket.IO), broker MQTT (Mosquitto), base de datos relacional (PostgreSQL en GCP), microservicio de auditoría y nodos IoT físicos (ESP32).
- Las operaciones de tratamiento de datos realizadas en el territorio de la República del Ecuador y en los servidores de Google Cloud Platform en los que se despliega la plataforma.

Esta política no aplica a:

- Sistemas o servicios de terceros enlazados desde la plataforma, pero fuera del control del equipo Agro-Smart.
- Datos que no sean datos personales en sentido técnico-jurídico (por ejemplo, datos de telemetría ambiental anónimos no vinculados a ningún usuario o dispositivo identificable), aunque dichos datos también son gestionados con criterios de seguridad de la información.

5. Definiciones y terminología

A efectos del presente documento, se adoptan las siguientes definiciones:

Término	Definición
Dato personal	Cualquier información relativa a una persona natural identificada o identificable. En el contexto de Agro-Smart, incluye nombre, apellido, dirección de correo electrónico, dirección IP de origen y datos de sesión asociados a un usuario.
Tratamiento	Cualquier operación realizada sobre datos personales, ya sea de forma automatizada o no, incluyendo la recolección, registro, organización, almacenamiento, adaptación, consulta, utilización, comunicación, limitación, supresión o destrucción.
Titular del dato	La persona natural a quien corresponden los datos personales objeto de tratamiento. En Agro-Smart, los titulares son los usuarios registrados (SuperAdministrador, Administrador, Agricultor).
Responsable del tratamiento	El equipo de desarrollo Agro-Smart, en el marco del Trabajo Final de Titulación de la UNL, que determina los fines y medios del tratamiento de datos personales.
Encargado del tratamiento	Tercero que trata datos personales por cuenta del responsable. En Agro-Smart, Google Cloud Platform actúa como encargado en lo relativo al alojamiento de la base de datos y la infraestructura de cómputo.
Base legal	Fundamento jurídico que legitima el tratamiento de datos personales. Las bases legales reconocidas por la LOPDP y utilizadas en este sistema son: ejecución de una relación contractual/prestación de servicio, cumplimiento de obligación legal, interés legítimo y consentimiento.
Dato técnico / telemetría	Información generada automáticamente por los nodos IoT (lecturas de humedad y temperatura) o por la infraestructura del sistema (logs, registros de sesión, metadatos de red), no asociada directamente a una persona, pero potencialmente vinculable a un usuario en calidad de operador del sistema.
JWT	JSON Web Token. Token criptográfico firmado utilizado para autenticar y autorizar las sesiones de usuario en la plataforma Agro-Smart. Contiene el identificador del usuario, su rol y el identificador de empresa (multi-tenancy).
Multi-tenancy	Arquitectura del sistema que permite aislar los datos de distintas empresas/fincas en un mismo sistema compartido. En Agro-Smart, el aislamiento se implementa a nivel de autenticación (JWT incluye empresa_identificador), autorización (filtrado SQL) y transporte en tiempo real (salas Socket.IO segregadas por empresa).
AFD	Autómata Finito Determinista. Motor de decisión que gestiona los estados y transiciones del sistema de riego automatizado. No genera datos personales directamente, pero registra transiciones asociadas a una parcela y, por tanto, vinculadas al Administrador o Agricultor responsable.
Broker MQTT	Servidor intermediario (Mosquitto) que recibe y distribuye mensajes desde y hacia los nodos IoT mediante el protocolo MQTT con cifrado TLS 1.2+. Gestiona credenciales de acceso de los dispositivos.
LOPDP	Ley Orgánica de Protección de Datos Personales del Ecuador, publicada en el Registro Oficial Suplemento No. 459 de 26 de mayo de 2021 y sus reglamentos.
GDPR	Reglamento General de Protección de Datos de la Unión Europea (Reglamento UE 2016/679). Referencia de buenas prácticas internacionales adoptada como guía estructural.
GCP	Google Cloud Platform. Plataforma de servicios en la nube de Google utilizada para el despliegue de la infraestructura productiva de Agro-Smart (Cloud Run, Cloud SQL, Artifact Registry).
RabbitMQ	Middleware de mensajería utilizado por el microservicio de auditoría para la recepción y persistencia asíncrona de eventos de auditoría generados por el backend.
SuperAdministrador (rol AUDITOR)	Rol de máximos privilegios en el sistema, con visibilidad trans-tenant (entre empresas), creado exclusivamente para fines de auditoría, gestión de cuentas administrativas y supervisión global del inventario de dispositivos.

6. Información del responsable del tratamiento

Campo	Información
Nombre del sistema	Agro-Smart - Sistema Inteligente de Monitoreo y Control de Riego Agrícola
Responsable	Equipo de Desarrollo Agro-Smart - Universidad Nacional de Loja
Institución académica	Universidad Nacional de Loja (UNL), Facultad de la Energía, las Industrias y los Recursos Naturales No Renovables, Carrera de Computación
País de operación	Ecuador
Tipo de sistema	Académico-investigativo (Trabajo Final de Titulación). Sin fines comerciales en la versión actual.
Dirección de contacto para privacidad	eberson.guayllas@unl.edu.ec luis.d.armijos.r@unl.edu.ec stalin.tapia@unl.edu.ec freddy.matailo@unl.edu.ec manuel.tamayo@unl.edu.ec
Correo electrónico del sistema	agrosmart.ecu@gmail.com (correo funcional del sistema; no es canal oficial para solicitudes de privacidad)
Supervisión académica	Ing. Roberth Figueroa (Docente, Ingeniería en Computación, UNL)

En tanto el proyecto Agro-Smart se encuentre en fase académica, la responsabilidad del tratamiento de datos personales recae en el equipo de desarrollo bajo la supervisión institucional de la Universidad Nacional de Loja. En el caso de una futura implementación comercial o institucional, el responsable deberá ser determinado e inscrito conforme a lo dispuesto en la Ley Orgánica de Protección de Datos Personales del Ecuador.

7. Datos personales recopilados

El sistema Agro-Smart recopila únicamente los datos personales estrictamente necesarios para la prestación de sus funcionalidades. A continuación, se detalla cada categoría de dato personal tratado, identificando su origen, finalidad y carácter.

7.1 Datos de identificación y cuenta de usuario

Los siguientes datos son recopilados en el momento del registro de una cuenta de usuario en la plataforma, ya sea por el primer Administrador (auto-registro) o por un Administrador para dar de alta a un Agricultor:

Campo en base de datos	Dato personal	Origen	Obligatorio
nombre	Nombre de pila del usuario	Proporcionado por el usuario	Sí
apellido	Apellido del usuario	Proporcionado por el usuario	Sí
correo (institucional)	Dirección de correo institucional generada automáticamente por el sistema a partir del nombre y apellido (correoInstitucional.js)	Generado por el sistema	Sí
correo_validacion	Dirección de correo electrónico personal o de validación proporcionada por el usuario para verificar su identidad	Proporcionado por el usuario	Sí
contra_hash	Hash bcrypt de la contraseña del usuario (algoritmo bcrypt, 10 rondas de sal). La contraseña en texto plano nunca se almacena.	Derivado de la contraseña proporcionada	Sí
google_id	Identificador único de cuenta Google (campo 'sub' del token OAuth), si el usuario vincula su cuenta de Google para validación de identidad. Puede ser nulo.	Obtenido de Google OAuth	No
rol	Rol del usuario en el sistema: ADMINISTRADOR, AGRICULTOR o AUDITOR	Asignado por el sistema o el Administrador	Sí
empresa_identificador	Identificador de la empresa/finca a la que pertenece el usuario, para el aislamiento multi-tenant de datos	Asignado por el Administrador	Sí
avatar_id	Referencia a un avatar visual seleccionado por el usuario de entre las opciones disponibles en la plataforma. No es una fotografía real.	Seleccionado por el usuario	No

7.2 Datos de seguridad y control de acceso

La plataforma recopila automáticamente los siguientes datos con finalidad de seguridad del sistema:

Campo en base de datos	Dato / Metadato	Finalidad
intento_login.correo_intentado	Dirección de correo electrónico con la que se intentó iniciar sesión	Detección de ataques de fuerza bruta y auditoría de seguridad
intento_login.ip_origen	Dirección IP del origen del intento de inicio de sesión (IPv4 o IPv6)	Detección de accesos no autorizados y análisis de seguridad
intento_login.exitoso / motivo_fallo	Resultado del intento de autenticación y motivo del fallo	Gestión de bloqueos por intentos fallidos (máximo 3 antes de bloqueo)
usuario.intentos_fallidos / bloqueado	Contador de intentos fallidos y estado de bloqueo de la cuenta	Control automático de seguridad: bloqueo tras 3 intentos fallidos consecutivos
sesion_usuario.token_jwt	Token JWT asociado a la sesión activa del usuario	Gestión del ciclo de vida de sesiones (8 horas de duración configurable)
sesion_usuario.fecha_inicio / fecha_expiracion / estado	Metadatos de la sesión: inicio, expiración y estado (ACTIVA, EXPIRADA, CERRADA, REVOCADA)	Trazabilidad y control de sesiones activas
token_recuperacion.token	Token de recuperación de contraseña (de un solo uso, con expiración)	Proceso seguro de recuperación de acceso a la cuenta



Nota de privacidad: La dirección IP es considerada dato personal bajo la LOPDP cuando puede vincularse a una persona identificada. Su almacenamiento tiene finalidad exclusiva de seguridad y auditoría, conforme al principio de minimización de datos.

7.3 Datos operativos y de configuración

Los siguientes datos, si bien no son datos personales en sentido estricto, están directamente asociados a un usuario (Administrador o Agricultor) y, por tanto, forman parte del tratamiento:

- Nombre descriptivo de parcelas y su ubicación descriptiva y coordenadas geográficas (latitud y longitud, si el usuario las proporciona).
- Parámetros de configuración de riego por parcela (umbrales de humedad Umin, Umax, Umin_crítico; temperatura crítica T_máximo; intervalo de adquisición Tmin) y modalidad de configuración (perfil predeterminado o manual).
- Historial inmutable de configuraciones de riego aplicadas a cada parcela (tabla historial_aplicacion_perfil), incluyendo la fecha de aplicación.
- Programaciones de riego por día de la semana y hora configuradas por el Administrador.
- Datos de asignación de agricultores a parcelas (tabla parcela_asignada).

8. Datos técnicos recopilados e información proveniente de dispositivos IoT

8.1 Telemetría de sensores IoT

Los nodos IoT basados en microcontroladores ESP32, desplegados en campo, capturan y transmiten al broker MQTT (con cifrado TLS 1.2+) los siguientes datos de forma periódica y automática:

Campo en base de datos	Variable ambiental	Unidad	Tipo de sensor
lectura.humedad	Humedad del suelo	% (porcentaje)	Sensor capacitivo de humedad
lectura.temperatura	Temperatura ambiente	°C (grados Celsius)	Sensor DS18B20 u equivalente
lectura.timestamp_utc	Marca de tiempo de la lectura (UTC)	TIMESTAMP TZ	Generado por el sistema
lectura.estado_lectura	Estado de validez de la lectura (VALIDA, ERROR_FUERA_DE_RANGO, ERROR_SENSOR_SIN_RESPUESTA)	Enum	Generado por el sistema

Estas lecturas no contienen datos personales de forma directa. Sin embargo, al estar vinculadas a una parcela y, a través de esta, a usuarios específicos (Administrador y Agricultores asignados), se tratan con los mismos criterios de seguridad que los datos personales.

8.2 Credenciales de dispositivos IoT

Cada nodo IoT registrado en el sistema dispone de credenciales de autenticación para el broker MQTT, almacenadas en la tabla credencial_nodo:

- Tipo de credencial: USUARIO_CONTRA (usuario y contraseña MQTT) o X509 (certificado).
- Identificador del dispositivo: cadena única que identifica al nodo en el broker.
- Hash del secreto: el secreto de autenticación se almacena únicamente en forma hasheada (secreto_hash); nunca en texto plano.
- Estado de la credencial: ACTIVA, REVOCADA o EXPIRADA.

La gestión de credenciales de nodos es responsabilidad del Administrador de la empresa/finca. El sistema implementa registro automático de credenciales MQTT (MQTT_AUTO_REGISTER) con revocación programática.

8.3 Datos del Autómata Finito Determinista (AFD)

El motor AFD que gestiona la lógica de riego genera y persiste los siguientes registros operativos:

- Estado actual del AFD por parcela (S0-Monitoreo, S1-Evaluación, S2-Riego Activo, S3-Riego Detenido, S4-Fallo).
- Historial completo de transiciones del AFD: estado origen, estado destino, símbolo disparador, marca de tiempo, valores de humedad y temperatura en el momento de la transición, y causa de la transición.

Estos datos de auditoría operativa permiten la trazabilidad completa del comportamiento del sistema de riego y son accesibles por el Administrador de la parcela y por el rol SuperAdministrador/Auditor.

8.4 Datos del microservicio de auditoría

El sistema implementa un microservicio de auditoría independiente que recibe eventos del backend principal a través de una cola de mensajería RabbitMQ. Los eventos de auditoría incluyen:

- Categoría del evento: AUTENTICACION, GESTION_USUARIOS, GESTION_PARCELAS, GESTION_NODOS, CONFIGURACION_RIEGO, ALERTAS, REPORTE, SISTEMA.
- Acción específica: LOGIN_EXITOSO, LOGIN_FALLIDO, CUENTA_BLOQUEADA, USUARIO_REGISTRADO, PARCELA_CREADA, etc.
- Actor del evento: identificador de usuario, correo electrónico, rol y empresa_identificador.
- Recurso afectado: tipo de entidad (usuario, parcela, nodo, etc.) e identificador del recurso.
- Contexto técnico: dirección IP de la solicitud y ruta de la API invocada.
- Metadatos adicionales: información complementaria según el tipo de evento.



Los registros de auditoría están diseñados para excluir información sensible: los campos 'contra', 'password', 'token', 'captchaToken', 'refreshToken', 'contraHash' y 'secretoHash' son filtrados activamente antes de ser emitidos al log de auditoría (CAMPOS_SENSIBLES en audit.emitter.js).

9. Finalidades del tratamiento de datos

Los datos personales y técnicos recopilados por Agro-Smart son tratados exclusivamente para las siguientes finalidades, determinadas con anterioridad a la recolección:

ID	Finalidad	Datos utilizados	Base legal
F-01	Gestión de cuentas de usuario y control de acceso al sistema. Autenticación mediante correo electrónico y contraseña; emisión y verificación de tokens JWT; gestión del ciclo de vida de sesiones.	Nombre, apellido, correo, hash de contraseña, rol, empresa_identificador, token JWT, datos de sesión.	Ejecución del servicio solicitado (LOPD Art. 7)
F-02	Aislamiento multi-tenant de datos por empresa/finca. Garantizar que cada empresa acceda únicamente a sus propios datos (parcelas, nodos, lecturas, alertas, configuraciones).	empresa_identificador (incluido en JWT y en todas las entidades de negocio).	Ejecución del servicio solicitado; interés legítimo de seguridad.
F-03	Monitoreo en tiempo real de variables ambientales del cultivo (humedad del suelo y temperatura). Visualización en dashboard mediante WebSocket (Socket.IO/WSS).	Lecturas de sensores (humedad, temperatura, timestamp), identificador de parcela y nodo.	Ejecución del servicio solicitado.
F-04	Automatización del riego mediante el modelo AFD. Activación y desactivación del actuador (relé-bomba) en función de los umbrales configurados y las lecturas del sensor.	Lecturas de sensores, configuración de riego de la parcela, estado del AFD.	Ejecución del servicio solicitado.
F-05	Generación de alertas automáticas ante condiciones críticas (humedad baja, temperatura alta, fallo de sensor o actuador, pérdida de conectividad). Notificación al usuario en tiempo real.	Lecturas de sensores, estado del AFD, datos de la parcela y el nodo, correo del usuario (para notificaciones por email).	Ejecución del servicio solicitado; interés legítimo (protección del cultivo).
F-06	Gestión de reportes históricos. Generación de reportes diarios, semanales y mensuales de variables ambientales y activaciones del riego, en formatos PDF y CSV.	Lecturas históricas de sensores, datos de activación del AFD, parcela asociada.	Ejecución del servicio solicitado.
F-07	Seguridad del sistema. Detección y prevención de accesos no autorizados, ataques de fuerza bruta y actividades anómalas. Bloqueo automático de cuentas tras 3 intentos fallidos.	Dirección IP de origen, correo intentado, contador de intentos fallidos, estado de bloqueo, reCAPTCHA.	Interés legítimo (seguridad del sistema y protección de usuarios).
F-08	Auditoría del sistema. Registro cronológico e inmutable de acciones realizadas por usuarios y por el propio sistema, para fines de trazabilidad, control y supervisión.	Actor del evento (usuario_id, correo, rol, empresa), recurso afectado, contexto técnico (IP, ruta), metadatos del evento.	Obligación legal (trazabilidad requerida por buenas prácticas); interés legítimo.
F-09	Recuperación de contraseña. Envío de un enlace de recuperación de un solo uso con tiempo de expiración al correo de validación del usuario.	Correo de validación, token de recuperación (hasheado), fecha de expiración.	Ejecución del servicio solicitado.
F-10	Comunicaciones del sistema. Envío de correos electrónicos transaccionales: activación de cuenta, recuperación de contraseña y notificaciones de alertas críticas.	Correo de validación o correo institucional del usuario.	Ejecución del servicio solicitado.

El sistema Agro-Smart NO realiza las siguientes actividades de tratamiento de datos: elaboración de perfiles de comportamiento de usuarios con fines comerciales, cesión o venta de datos personales a terceros, análisis predictivo de comportamiento (funcionalidad prevista para versiones futuras), inteligencia artificial sobre datos personales, ni publicidad dirigida.

10. Base legal del tratamiento

Todo tratamiento de datos personales realizado por Agro-Smart se fundamenta en al menos una de las siguientes bases legales, conforme a la Ley Orgánica de Protección de Datos Personales del Ecuador (LOPD):

Base legal	Descripción en el contexto de Agro-Smart
Ejecución de una relación contractual o prestación de servicio (LOPD Art. 7 lit. b)	El tratamiento de datos de identificación (nombre, apellido, correo, contraseña), credenciales de sesión y datos operativos (parcelas, nodos, configuraciones) es necesario para ejecutar la prestación del servicio de monitoreo y control de riego que el usuario solicita al registrarse en la plataforma.
Consentimiento del titular (LOPD Art. 7 lit. a)	El usuario, al completar el proceso de registro y aceptar la presente política, otorga su consentimiento explícito para el tratamiento de sus datos personales con las finalidades descritas en la Sección 9. El consentimiento es revocable en cualquier momento mediante el ejercicio del derecho de supresión.
Interés legítimo del responsable (LOPD Art. 7 lit. f)	El tratamiento de la dirección IP, los intentos de inicio de sesión y los registros de auditoría se realiza sobre la base del interés legítimo del equipo Agro-Smart en garantizar la seguridad del sistema, prevenir accesos no autorizados y mantener la integridad de los datos de todos los usuarios. Este interés legítimo ha sido ponderado y no prevalece sobre los derechos y libertades fundamentales de los titulares.
Cumplimiento de obligación legal (LOPD Art. 7 lit. c)	El mantenimiento de registros de auditoría responde a las obligaciones de trazabilidad y rendición de cuentas (accountability) impuestas por los principios de la LOPD y los estándares de seguridad de la información adoptados como referencia (ISO/IEC 27001).

11. Consentimiento del usuario

Al acceder a la plataforma Agro-Smart y completar el proceso de registro, el usuario presta su consentimiento para el tratamiento de sus datos personales conforme a lo descrito en la presente política. El consentimiento cumple las siguientes características:

- Libre: el usuario no está obligado a proporcionar sus datos. Sin embargo, los datos marcados como obligatorios en la Sección 7.1 son necesarios para acceder a las funcionalidades del sistema.
- Específico: el consentimiento se refiere exclusivamente a las finalidades descritas en la Sección 9 de este documento.
- Informado: el usuario recibe esta política antes de prestar su consentimiento y tiene acceso a ella en todo momento.
- Inequívoco: el consentimiento se manifiesta mediante una acción afirmativa clara (aceptación expresa de la política durante el proceso de registro).

El usuario puede revocar su consentimiento en cualquier momento, sin que ello afecte a la licitud del tratamiento basado en el consentimiento previo a su retirada. La revocación del consentimiento implica la imposibilidad de acceder a las funcionalidades de la plataforma y deberá solicitarse a través de los canales indicados en la Sección 18.



12. Uso de cookies y tecnologías de seguimiento

Tras el análisis del código fuente de la plataforma Agro-Smart (frontend React servido mediante Nginx; backend Node.js con Express), se determinan los siguientes puntos respecto al uso de cookies y tecnologías de seguimiento:

12.1 Cookies de sesión

La versión actual de Agro-Smart implementa la autenticación basada en tokens JWT, que son almacenados en el lado del cliente mediante mecanismos de almacenamiento de la aplicación (contexto de React / estado de la aplicación). No se ha identificado en el código fuente analizado el uso de cookies HTTP de sesión de tipo tradicional (Set-Cookie) para la gestión de autenticación.

12.2 Google reCAPTCHA

La plataforma implementa Google reCAPTCHA (servicio de Google LLC) en el formulario de inicio de sesión, con la finalidad de verificar que el acceso lo realiza un ser humano y prevenir ataques automatizados. El uso de reCAPTCHA implica el envío de información al servicio de Google para su análisis, incluyendo potencialmente la dirección IP del usuario y datos de comportamiento en el formulario. El usuario debe estar informado de que este servicio está sujeto a la Política de Privacidad de Google (disponible en <https://policies.google.com/privacy>).

12.3 Comunicaciones en tiempo real (WebSocket)

La plataforma utiliza Socket.IO sobre protocolo WSS (WebSocket Secure) para la transmisión en tiempo real de lecturas de sensores, alertas y transiciones del AFD. Esta tecnología no implica el uso de cookies de rastreo, sino el establecimiento de conexiones persistentes autenticadas mediante JWT.

12.4 Tecnologías de seguimiento analítico

En la versión actual del sistema, analizada a partir del código fuente disponible, no se ha identificado la integración de herramientas de análisis web de terceros (Google Analytics, Matomo, etc.) ni de tecnologías de rastreo publicitario (píxeles de seguimiento, fingerprinting). En caso de incorporarse en versiones futuras, esta política será actualizada y se solicitará el consentimiento expreso del usuario.

13. Compartición de información con terceros y servicios externos

13.1 Principio general

Agro-Smart NO vende, arrienda, cede ni comercializa datos personales de sus usuarios a terceros para ninguna finalidad. Conforme a la restricción C-05 de la Especificación de Requisitos del sistema, los datos de uso del sistema no serán compartidos con terceros con fines distintos a los requeridos para la prestación del servicio.

La transferencia de datos a servicios externos se limita estrictamente a los proveedores técnicos necesarios para la operación del sistema, en su condición de encargados del tratamiento, y siempre bajo las garantías contractuales y técnicas descritas a continuación.

13.2 Servicios externos utilizados en el sistema

Proveedor	Servicio utilizado	Datos transferidos	Finalidad	País de operación
Google LLC - Google Cloud Platform (GCP)	Cloud Run (cómputo serverless), Cloud SQL (base de datos PostgreSQL), Artifact Registry (imágenes Docker)	Todos los datos almacenados en la base de datos del sistema, incluyendo datos personales de usuarios y datos operativos.	Alojamiento y operación de la infraestructura del sistema.	EE.UU. / múltiples regiones
Google LLC - Gmail SMTP (API)	Envío de correos electrónicos transaccionales (activación de cuenta, recuperación de contraseña, alertas)	Dirección de correo del destinatario y contenido del mensaje (nombre del usuario, enlace de acción o descripción de la alerta).	Comunicaciones del sistema hacia el usuario.	EE.UU.
Google LLC - reCAPTCHA v2/v3	Verificación de comportamiento humano en el formulario de inicio de sesión	Datos de comportamiento en el formulario e IP del usuario, enviados a Google para análisis.	Prevención de ataques automatizados (bots).	EE.UU.
Eclipse Foundation - Mosquitto MQTT Broker	Broker de mensajería IoT (software de código abierto, desplegado en infraestructura propia)	Datos de telemetría de sensores (humedad, temperatura) y credenciales de dispositivos IoT.	Transmisión de telemetría desde nodos IoT al backend.	Infraestructura propia (GCP o local)
RabbitMQ (open source) / nube externa en evaluación	Cola de mensajería para el microservicio de auditoría	Eventos de auditoría (categoría, acción, actor, recurso, contexto). Los campos sensibles son filtrados antes de la emisión.	Persistencia asíncrona de registros de auditoría.	EE.UU. (instancia AWS indicada en .env para entorno compartido) o local

Todos los proveedores externos de nube (Google LLC, Amazon Web Services) disponen de sus propias políticas de privacidad y están sujetos al marco contractual de Data Processing Agreements (DPA) con sus clientes. La transferencia de datos a estos proveedores se realiza sobre la base del interés legítimo de operación del servicio y, en el caso de Google Cloud, al amparo de los compromisos contractuales estándar de Google como encargado del tratamiento.

13.3 Transferencias internacionales de datos

Dado que la infraestructura de Google Cloud Platform puede alojar datos en centros de datos ubicados fuera del Ecuador, existe la posibilidad de transferencias internacionales de datos personales. El equipo Agro-Smart adopta las siguientes medidas de mitigación:

- Selección de regiones GCP más próximas (preferencia por us-central1 u otras regiones americanas) para reducir la latencia y los riesgos regulatorios.
- Dependencia de los Términos del Servicio de Google Cloud y de sus compromisos de protección de datos, que incluyen salvaguardas técnicas y contractuales.
- Cifrado en tránsito (TLS 1.2+) para todas las comunicaciones de datos, incluyendo la base de datos PostgreSQL (comunicación backend ↔ Cloud SQL por VPC privada con TLS interno).



14. Conservación de la información

Los datos personales serán conservados únicamente durante el tiempo necesario para cumplir las finalidades para las que fueron recopilados, y en todo caso no más allá de lo permitido por la legislación aplicable. Los criterios de conservación adoptados por Agro-Smart son los siguientes:

Categoría de dato	Período de conservación	Criterio / Evento de supresión
Datos de cuenta de usuario (nombre, apellido, correo, rol)	Durante la vigencia de la cuenta activa + tiempo indefinido.	Cierre voluntario de la cuenta o decisión de supresión por el Administrador.
Hash de contraseña	Durante la vigencia de la cuenta activa. Se suprime con la cuenta.	Cierre de la cuenta o solicitud de supresión del titular.
Registros de intentos de inicio de sesión (intento_login)	90 días o hasta que el riesgo de seguridad asociado haya sido resuelto.	Supresión automática programada o manual por el Administrador de seguridad.
Tokens JWT de sesión	Máximo 8 horas (duración configurable). Se invalidan automáticamente al expirar, cerrar sesión o ser revocados.	Expiración automática o acción de cierre de sesión (logout).
Tokens de recuperación de contraseña	Hasta su uso o su expiración (diseñados como de un solo uso con tiempo de vida limitado).	Uso exitoso o expiración automática.
Datos de telemetría (lecturas de sensores)	Histórico indefinido mientras la parcela esté activa en el sistema. Históricos se retienen hasta 3 años.	Eliminación de la parcela o solicitud de supresión.
Transiciones del AFD (historial de riego)	Histórico indefinido mientras la parcela esté activa.	Eliminación de la parcela o solicitud de supresión.
Registros de auditoría	Mínimo 1 año, por necesidades de trazabilidad y seguridad.	Supresión programada por el SuperAdministrador/Auditor.
Reportes generados	Conservados mientras la parcela esté activa y el usuario no los elimine.	Eliminación manual por el Administrador o supresión de la parcela.

Transcurridos los períodos de conservación indicados, los datos serán suprimidos de forma segura de los sistemas de almacenamiento de Agro-Smart. En el caso de datos alojados en Google Cloud SQL, la supresión se realiza mediante operaciones DELETE estándar de PostgreSQL, sin perjuicio de los períodos de retención propios de las copias de seguridad automáticas de GCP.

15. Medidas de seguridad implementadas

Agro-Smart implementa medidas de seguridad técnicas y organizativas orientadas a garantizar la confidencialidad, integridad y disponibilidad de los datos personales tratados, en alineación con los principios de la LOPDP, ISO/IEC 27001 e ISO/IEC 27701. Las medidas descritas a continuación son las identificadas en el código fuente y la documentación del sistema:

15.1 Seguridad en la autenticación

- Hashing de contraseñas: las contraseñas de los usuarios se almacenan exclusivamente como hashes generados con el algoritmo bcrypt con 10 rondas de sal (BCRYPT_ROUNDS=10). La contraseña en texto plano nunca es almacenada ni transmitida fuera del proceso de verificación.
- Bloqueo de cuentas por fuerza bruta: tras 3 intentos de inicio de sesión fallidos consecutivos, la cuenta es bloqueada automáticamente. El desbloqueo requiere la recuperación de contraseña mediante enlace de un solo uso enviado al correo de validación.
- Google reCAPTCHA: integrado en el formulario de login para mitigar ataques de bots y credential stuffing.
- JSON Web Tokens (JWT): los tokens de sesión son firmados con una clave secreta (JWT_SECRET) y tienen una caducidad de 8 horas (configurable). El payload incluye el identificador del usuario, su rol y su empresa_identificador.
- Tokens de recuperación de contraseña de un solo uso: generados mediante crypto.randomBytes, hasheados antes de ser almacenados, con tiempo de expiración definido.

15.2 Seguridad en el transporte de datos

- TLS 1.2+ en todas las comunicaciones: las conexiones HTTPS (API REST y WebSocket), MQTT/TLS (broker Mosquitto) y la comunicación interna PostgreSQL (VPC privada de GCP) utilizan cifrado TLS versión 1.2 o superior.
- Certificados X.509 autofirmados para el broker MQTT: el broker Mosquitto utiliza certificados de autoridad de certificación (CA) propia para autenticar las conexiones de los nodos IoT.
- Configuración CORS restrictiva: el backend define explícitamente el origen permitido (CORS_ORIGIN), rechazando solicitudes de orígenes no autorizados.

15.3 Seguridad en la autorización y el acceso a datos

- Control de acceso basado en roles (RBAC): el middleware de autorización (auth.middleware.js) verifica el rol del usuario en cada petición y restringe el acceso a los recursos según los roles permitidos (ADMINISTRADOR, AGRICULTOR, AUDITOR).
- Aislamiento multi-tenant a nivel de consulta SQL: todas las consultas a la base de datos incluyen el filtro empresa_identificador, garantizando que cada empresa acceda exclusivamente a sus propios datos.
- Salas Socket.IO segregadas por empresa: el canal WebSocket implementa enrutamiento por empresa_identificador, impidiendo que eventos de una empresa sean recibidos por otra.
- Principio de mínimo privilegio en GCP: mediante IAM, se habilitaron exclusivamente las APIs necesarias para la operación del sistema (Cloud Run API, Cloud SQL Admin API, Artifact Registry API, Compute Engine API, Cloud Build API, Service Networking API).

15.4 Seguridad de la infraestructura

- Contenedores Docker: los servicios (backend Node.js, frontend Nginx, base de datos PostgreSQL) se despliegan en contenedores aislados, reduciendo la superficie de ataque.
- Artifact Registry en GCP: las imágenes Docker se almacenan en un repositorio privado bajo control de IAM, garantizando la integridad y el origen de los artefactos desplegados.
- Base de datos en red privada VPC: la base de datos Cloud SQL no es accesible directamente desde Internet; la comunicación backend-base de datos se realiza exclusivamente dentro de la VPC privada de GCP.
- Variables de entorno para credenciales: las credenciales y secretos del sistema (JWT_SECRET, contraseñas de base de datos, credenciales MQTT, claves de correo) se gestionan mediante variables de entorno y no están embebidas en el código fuente.



15.5 Seguridad en el desarrollo

- Análisis de vulnerabilidades: el plan de calidad del sistema contempla el uso de npm audit (análisis de dependencias Node.js), OWASP ZAP (análisis dinámico de seguridad) y SonarQube (calidad y seguridad de código estático), con el criterio de cero vulnerabilidades críticas ($CVSS \geq 9.0$) sin corregir.
- Control de versiones con revisión de código: la rama principal del repositorio GitHub está protegida y requiere revisión de código (Pull Request) antes de cada merge.
- Filtrado de campos sensibles en auditoría: el módulo de auditoría (audit.emitter.js) excluye explícitamente los campos contra, password, token, captchaToken, refreshToken, contraHash y secretoHash de todos los registros de auditoría emitidos.

16. Derechos de los usuarios

En virtud de la Ley Orgánica de Protección de Datos Personales del Ecuador (LOPD), los titulares de datos personales tratados por Agro-Smart tienen reconocidos los siguientes derechos, que pueden ejercer en cualquier momento:

16.1 Catálogo de derechos

Derecho	Descripción en el contexto de Agro-Smart
Derecho de acceso	El usuario puede solicitar información completa sobre qué datos personales suyos trata Agro-Smart, con qué finalidad, durante cuánto tiempo y a quién han sido comunicados. Incluye el derecho a obtener una copia de sus datos personales.
Derecho de rectificación	El usuario puede solicitar la corrección de sus datos personales inexactos o incompletos (por ejemplo, corrección del nombre o del correo de validación).
Derecho de supresión («derecho al olvido»)	El usuario puede solicitar la eliminación de sus datos personales cuando ya no sean necesarios para los fines para los que fueron recopilados, cuando retire su consentimiento o cuando el tratamiento sea contrario a la LOPDP.
Derecho de oposición	El usuario puede oponerse al tratamiento de sus datos personales en los casos en que el tratamiento se base en el interés legítimo del responsable, salvo que existan razones imperiosas que prevalezcan sobre sus derechos.
Derecho a la portabilidad	El usuario puede solicitar recibir sus datos personales en un formato estructurado, de uso común y lectura mecánica (por ejemplo, CSV o JSON), o que sean transmitidos directamente a otro responsable del tratamiento.
Derecho a la limitación del tratamiento	El usuario puede solicitar que el tratamiento de sus datos sea limitado (por ejemplo, suspendido temporalmente) mientras se resuelve una disputa sobre la exactitud de los datos o la legitimidad del tratamiento.
Derecho a no ser objeto de decisiones automatizadas	En la versión actual de Agro-Smart, el único proceso automatizado que afecta directamente al usuario es el bloqueo de cuenta tras 3 intentos fallidos de login. El usuario tiene derecho a solicitar revisión manual de esta decisión.

16.2 Procedimiento para ejercer los derechos

Para ejercer cualquiera de los derechos descritos, el usuario deberá:

- Dirigir su solicitud al canal de contacto designado por el responsable del tratamiento (véase Sección 18), indicando claramente el derecho que desea ejercer.
- Identificarse fehacientemente, aportando información suficiente que permita verificar la titularidad de los datos objeto de la solicitud.
- Describir con la mayor precisión posible el alcance de su solicitud.

El responsable del tratamiento deberá dar respuesta a la solicitud en el plazo máximo de 15 días hábiles contados desde la recepción de la solicitud, conforme a lo dispuesto en la LOPDP. En caso de que la solicitud sea compleja o numerosa, este plazo podrá prorrogarse hasta por un período adicional de 15 días hábiles, previa notificación al solicitante.

Si el responsable del tratamiento no atiende la solicitud o la deniega sin causa justificada, el titular del dato tiene derecho a presentar una reclamación ante la Autoridad de Protección de Datos Personales del Ecuador.



17. Responsabilidades del usuario

El uso de la plataforma Agro-Smart conlleva determinadas responsabilidades para el usuario, quien deberá:

- Proporcionar información veraz, exacta y actualizada en el momento del registro y durante el uso del sistema. El usuario es responsable de la exactitud de los datos que proporciona.
- Mantener la confidencialidad de sus credenciales de acceso (correo electrónico y contraseña). No deberá compartir sus credenciales con terceros ni permitir el uso de su cuenta por personas no autorizadas.
- Notificar al Administrador de su empresa/finca, o directamente al equipo Agro-Smart, tan pronto como tenga conocimiento de cualquier acceso no autorizado a su cuenta o de cualquier incidente de seguridad.
- Utilizar la plataforma conforme a su finalidad agrícola y operativa, absteniéndose de realizar acciones que puedan comprometer la seguridad del sistema, la privacidad de otros usuarios o la integridad de los datos.
- El Administrador de cada empresa/finca tiene la responsabilidad adicional de gestionar correctamente las cuentas de los Agricultores bajo su cargo, garantizando que se les asignen únicamente los permisos necesarios para el desempeño de sus funciones (principio de mínimo privilegio a nivel de negocio).
- Informar al equipo de su empresa/finca sobre las condiciones de uso y privacidad de la plataforma cuando sea el Administrador quien invita a nuevos usuarios.

18. Protección de menores de edad

La plataforma Agro-Smart está diseñada para su uso por personas mayores de 18 años, en el contexto de la gestión agrícola profesional o académica. El sistema no recopila datos personales de menores de edad de forma intencionada.

En caso de que el equipo Agro-Smart tenga conocimiento de que se han recopilado datos personales de un menor de edad sin el consentimiento previo verificable de sus representantes legales, tomará las medidas necesarias para eliminar dicha información de sus sistemas de la manera más expedita posible.

Si un padre, madre o tutor legal tiene conocimiento de que su hijo menor de edad ha proporcionado datos personales a la plataforma sin su consentimiento, deberá contactar al equipo Agro-Smart a través de los canales indicados en la Sección 19.

19. Gestión de incidentes de seguridad relacionados con datos personales

19.1 Definición de incidente

A efectos de esta política, se entiende por incidente de seguridad de datos personales cualquier violación de la seguridad que ocasione, de manera accidental o ilícita, la destrucción, pérdida, alteración, comunicación no autorizada o acceso no autorizado a datos personales tratados por Agro-Smart.

19.2 Clasificación de incidentes

Nivel	Descripción	Ejemplos
Crítico	Compromiso confirmado de datos personales con potencial impacto significativo en los titulares.	Exfiltración de base de datos de usuarios; acceso no autorizado a cuentas de Administrador; exposición de credenciales en repositorio público.
Alto	Incidente de seguridad con potencial de comprometer datos personales, pero no confirmado.	Vulnerabilidad crítica detectada en la API; comportamiento anómalo sospechoso en registros de auditoría.
Medio	Incidente con impacto limitado o que afecta únicamente datos técnicos no directamente identificables.	Pérdida temporal de telemetría de sensores; caída del microservicio de auditoría.
Bajo	Incidentes menores de seguridad sin impacto directo en datos personales.	Intentos fallidos de login aislados; error de configuración sin exposición de datos.

19.3 Procedimiento de respuesta

Ante un incidente de seguridad relacionado con datos personales, el equipo Agro-Smart seguirá el siguiente procedimiento:

- Detección y contención: identificación del incidente, limitación del alcance del daño y preservación de la evidencia disponible en los registros de auditoría.
- Evaluación del impacto: determinación del tipo de datos afectados, número de titulares potencialmente afectados y riesgo para sus derechos y libertades.
- Notificación a la autoridad de control: en caso de que el incidente suponga un riesgo para los derechos de los titulares, notificación a la Autoridad de Protección de Datos Personales del Ecuador en el plazo máximo de 72 horas desde que se tenga conocimiento del incidente, conforme a la LOPDP.
- Notificación a los afectados: si el incidente supone un alto riesgo para los derechos y libertades de los titulares, notificación a los usuarios afectados sin dilación indebida, indicando la naturaleza del incidente, los datos afectados y las medidas adoptadas.
- Remediación: implementación de las correcciones técnicas u organizativas necesarias para evitar la repetición del incidente.
- Documentación: registro del incidente, de su análisis y de las medidas adoptadas en el sistema de gestión de incidencias (GitHub Issues), conforme al Plan de Pruebas y QA del sistema.

20. Modificaciones de la Política de Privacidad

El equipo Agro-Smart se reserva el derecho de actualizar o modificar la presente Política de Privacidad en cualquier momento, con el fin de reflejar cambios en el sistema, en la legislación aplicable o en las prácticas de privacidad adoptadas.

Ante cualquier modificación sustancial de la política, el equipo Agro-Smart adoptará las siguientes medidas:

- Publicación de la versión actualizada en la plataforma web de Agro-Smart, con indicación clara de la fecha de entrada en vigor de la nueva versión.
- Actualización del historial de versiones incluido en la Sección 1 de este documento.
- Notificación a los usuarios registrados mediante un aviso visible en la plataforma o, si el cambio es significativo, mediante comunicación directa al correo electrónico de validación registrado.

Se consideran modificaciones sustanciales, entre otras: cambios en las finalidades del tratamiento, incorporación de nuevas categorías de datos personales, cambios en los proveedores de servicios de nube que impliquen nuevas transferencias internacionales, y modificaciones en los períodos de conservación de datos.

El uso continuado de la plataforma por parte del usuario tras la notificación de cambios implicará la aceptación de la versión actualizada de la política. En caso de que el usuario no acepte los cambios, deberá ejercer su derecho de supresión y cesar el uso de la plataforma.

21. Información de contacto

Para cualquier consulta, solicitud o reclamación relacionada con el tratamiento de datos personales en la plataforma Agro-Smart, los titulares pueden dirigirse a:

Canal	Información
Correo electrónico funcional del sistema	agrosmart.ecu@gmail.com
Correo de contacto para privacidad	eberson.guayllas@unl.edu.ec luis.d.armijos.r@unl.edu.ec stalin.tapia@unl.edu.ec freddy.matailo@unl.edu.ec manuel.tamayo@unl.edu.ec
Institución académica	Universidad Nacional de Loja - Carrera de Computación, Loja, Ecuador
Autoridad de control (Ecuador)	Superintendencia de Protección de Datos Personales del Ecuador - https://www.supercom.gob.ec



22. Referencias normativas

La presente Política de Privacidad ha sido elaborada tomando como referencia los siguientes instrumentos normativos, estándares internacionales y documentos técnicos:

Referencia	Título / Descripción	Año / Versión
LOPD (Ecuador)	Ley Orgánica de Protección de Datos Personales del Ecuador. Registro Oficial Suplemento No. 459 de 26 de mayo de 2021.	2021
GDPR	Reglamento General de Protección de Datos - Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo. Referencia de buenas prácticas internacionales.	2016 / vigente
ISO/IEC 27001:2022	Information security, cybersecurity and privacy protection - Information security management systems - Requirements.	2022
ISO/IEC 27701:2019	Security techniques - Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management - Requirements and guidelines.	2019
ISO/IEC 29134:2017	Information technology - Security techniques - Guidelines for privacy impact assessment.	2017
ISO/IEC 30141:2018	Internet of Things (IoT) - Reference Architecture. Referencia arquitectural para sistemas IoT.	2018
Privacy by Design	Principios de Privacidad por Diseño - Ann Cavoukian, Information and Privacy Commissioner of Ontario, Canada.	1995 / revisado
OWASP Top 10	Open Web Application Security Project - Top 10 Web Application Security Risks. Referencia de seguridad para el desarrollo del backend Node.js.	2021
ERS Agro-Smart v0.5	Especificación de Requisitos de Software del proyecto Agro-Smart - ISO/IEC/IEEE 29148:2018. UNL, Carrera de Computación.	Julio 2026
Plan de Pruebas Agro-Smart v1.1	Plan de Pruebas, Usabilidad y Aseguramiento de Calidad - ISO/IEC/IEEE 29119. UNL, Carrera de Computación.	Junio 2026

23. Anexos

Anexo A - Inventario de datos personales tratados por Agro-Smart

El siguiente inventario consolida todos los datos personales tratados por el sistema, su categoría y los módulos del sistema que los procesan:

Dato personal	Tabla BD	Módulo(s) que lo tratan	Categoría LOPDP	¿Dato sensible?
Nombre y apellido	usuario	Auth, Usuarios, Auditoría	Identificativo	No
Correo institucional (generado)	usuario	Auth, Email, Auditoría	Identificativo / Contacto	No
Correo de validación (personal)	usuario	Auth, Email, Recuperación	Identificativo / Contacto	No
Hash de contraseña (bcrypt)	usuario	Auth	Credencial de seguridad	No (hash, no texto)
Google ID (OAuth)	usuario	Auth (opcional)	Identificativo	No
Empresa_identificador	usuario, parcela, nodo, perfil	Todos los módulos (multi-tenancy)	Organizativo	No
Avatar_id	usuario	Frontend (UI)	Preferencia visual	No
Dirección IP (login)	intento_login	Auth, Auditoría	Técnico-identificativo	No (bajo contexto)
Token JWT (sesión activa)	sesion_usuario	Auth	Credencial de sesión	No (temporal)
Token de recuperación (hash)	token_recuperacion	Auth (recuperación)	Credencial temporal	No (hash)

Anexo B - Arquitectura de protección de datos en Agro-Smart

El siguiente diagrama conceptual resume las capas de protección de datos implementadas en el sistema:

Capa 1 - Transporte: TLS 1.2+ en HTTPS (API REST), WSS (WebSocket), MQTTS (broker Mosquitto) y VPC privada (PostgreSQL ↔ backend).

Capa 2 - Autenticación: JWT firmado con HS256; bcrypt con 10 rondas; reCAPTCHA; bloqueo por fuerza bruta (3 intentos).

Capa 3 - Autorización: RBAC por rol (ADMINISTRADOR, AGRICULTOR, AUDITOR); aislamiento multi-tenant por empresa_identificador en SQL y Socket.IO.

Capa 4 - Infraestructura: Contenedores Docker aislados; Artifact Registry con control IAM; APIs GCP habilitadas selectivamente (principio de mínimo privilegio).

Capa 5 - Auditoría: Microservicio de auditoría desacoplado (RabbitMQ); filtrado activo de campos sensibles; registro inmutable de eventos por categoría y actor.

Anexo C - Flujo de datos personales en el proceso de autenticación

El siguiente esquema describe el flujo de datos personales durante el proceso de inicio de sesión, que es el proceso de mayor concentración de datos personales en el sistema:

1. El usuario introduce su correo de validación y contraseña en el formulario web (React). reCAPTCHA verifica que es humano.
2. La solicitud POST /api/auth/login es enviada al backend Node.js mediante HTTPS (TLS).
3. El backend verifica las credenciales: busca el usuario por correo, verifica el hash bcrypt de la contraseña y comprueba el estado de la cuenta.



4. Si la autenticación es exitosa: se genera un JWT firmado (8h de validez), se crea un registro de sesión en `sesion_usuario`, se registra el intento exitoso en `intento_login` y se emite el evento de auditoría `LOGIN_EXITOSO` a RabbitMQ.
5. Si la autenticación falla: se incrementa el contador de intentos fallidos, se registra el intento fallido en `intento_login` (con IP y motivo) y se emite el evento de auditoría correspondiente. Tras 3 fallos, la cuenta es bloqueada.
6. El JWT es devuelto al cliente, que lo almacena y lo incluye en el encabezado `Authorization: Bearer <token>` de todas las peticiones subsiguientes.

Documento elaborado por el Equipo Agro-Smart - Universidad Nacional de Loja, Carrera de Computación.

Versión 1.0 | Julio 2026 | Referencia: AGRS-POL-PRIV-001

Este documento ha sido elaborado siguiendo las buenas prácticas de la LOPDP (Ecuador), GDPR, ISO/IEC 27701 y Privacy by Design.